

CISCO CERTIFIED CYBEROPS ASSOCIATE (CBROPS 200-201)

Lab 10.6.7: Using Wireshark to Examine HTTP & HTTPS Traffic

Packet Capture Automation with tcpdump, Cleartext Credential Interception & TLS Cryptographic Dissection

COURSE MODULE

Module 10: Network Services

PROTOCOLS INSPECTED

HTTP (TCP 80) & HTTPS / TLS
(TCP 443)

CLI & GUI TOOLS

tcpdump & Wireshark Analyzer

WORKSTATION ENVIRONMENT

CyberOps Workstation VM
(analyst)

Objectives

- **Part 1: Capture and View Cleartext HTTP Traffic** — Use `tcpdump` to capture unencrypted HTTP web traffic to `httpdump.pcap` and extract cleartext authentication credentials from HTTP POST forms in Wireshark.
- **Part 2: Capture and View Encrypted HTTPS Traffic** — Record TLS-encrypted web sessions to `httpsdump.pcap`, dissect the TLS Record Layer, and analyze encrypted application data obfuscation.
- **Reflection & Security Architecture Evaluation** — Evaluate the cryptographic triad (Confidentiality, Integrity, Authentication) of HTTPS and examine how adversaries abuse SSL/TLS certificates for malicious operations.

Background / Scenario

The HyperText Transfer Protocol (HTTP) is the foundational application-layer protocol of the World Wide Web. However, legacy HTTP transmits all data — including web pages, session cookies, form inputs, and authentication credentials — in plain, unencrypted ASCII text.

HyperText Transfer Protocol Secure (HTTPS) secures web communications by encapsulating HTTP inside the Transport Layer Security (TLS) protocol. Through symmetric encryption, asymmetric key exchange, and X.509 digital certificates, HTTPS protects data from interception, tampering, and impersonation.

In this lab, network security analysts practice automated command-line packet sniffing using `tcpdump` and forensic packet dissection in Wireshark to contrast unencrypted HTTP against encrypted HTTPS traffic.

Part 1: Capture and View Cleartext HTTP Traffic

Step 1 & 2: Interface Discovery & Automated tcpdump Execution

Checking network interfaces on the CyberOps Workstation VM:

```
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:da:28:83 brd ff:ff:ff:ff:ff:ff
    inet 192.168.8.10/24 brd 192.168.8.255 scope global dynamic enp0s3
```

STEP 2.B — INTERFACE & ADDRESSING IDENTIFICATION

List the interfaces and their IP addresses displayed in the ip address output.

ANALYST FINDING:

- **lo (Loopback Interface):** IPv4 address `127.0.0.1/8` (and IPv6 `::1/128`), used for internal inter-process communication.
- **enp0s3 (Ethernet Adapter):** IPv4 address `192.168.8.10/24` (or VM IP `10.0.2.15/24`) with MAC address `08:00:27:da:28:83`, connecting the workstation to the local network and internet.

Starting tcpdump Capture & Generating HTTP Traffic

The command-line packet analyzer `tcpdump` is initiated to write full packet snapshots to disk:

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap
[sudo] password for analyst: cyberops
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
```

TCPDUMP FLAG	ARGUMENT PROVIDED	TECHNICAL PURPOSE & SOC BEST PRACTICE
<code>-i</code>	<code>enp0s3</code>	Binds packet capture specifically to the active Ethernet interface.
<code>-s</code>	<code>0</code> (or 262144)	Sets Snapshot Length (<code>snaplen</code>) to capture full packet payloads without truncation.
<code>-w</code>	<code>httpdump.pcap</code>	Writes raw libpcap binary capture data directly to file for Wireshark analysis.

The analyst navigates to the unencrypted test banking portal: `http://www.altoromutual.com/login.jsp` and logs in using username `Admin` and password `Admin`. Capture is terminated with `Ctrl + C`.

Step 3: Forensic Wireshark Analysis of httpdump.pcap

Opening `httpdump.pcap` in Wireshark and applying display filter `http` isolates the HTTP conversation. Selecting the `POST /doLogin` request reveals the HTML Form URL Encoded payload:

```
# Wireshark Packet Details (Frame 54 - HTTP POST /doLogin):
Hypertext Transfer Protocol
  POST /doLogin HTTP/1.1

  Host: www.altoromutual.com

  Content-Type: application/x-www-form-urlencoded

  Content-Length: 38

HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "uid" = "Admin"
  Form item: "passw" = "Admin"
  Form item: "btnSubmit" = "Login"
```

STEP 3.D — CLEARTEXT CREDENTIAL INTERCEPTION

What two pieces of information are displayed?

SOC INCIDENT EVIDENCE:

Expanding the `HTML Form URL Encoded: application/x-www-form-urlencoded` tree exposes the user's sensitive login credentials in **completely unencrypted plaintext**:

1. **Username Field (uid):** Admin
2. **Password Field (passw):** Admin

Security Impact: Any attacker eavesdropping on the local network (via Wi-Fi sniffing, ARP spoofing, or rogue gateway) captures full administrative credentials with zero decryption effort.

Part 2: Capture and View Encrypted HTTPS Traffic

Step 1: Capture HTTPS Traffic to `httpsdump.pcap`

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap
[sudo] password for analyst: cyberops
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
```

The browser navigates to the secure portal: `https://www.netacad.com`, and authentication is initiated.

STEP 1.B — URL SCHEME & SECURITY INDICATORS

What do you notice about the website URL?

ANALYST OBSERVATION:

- **Protocol Prefix:** The URL begins with `https://` (HyperText Transfer Protocol Secure) rather than `http://`.
- **Security Padlock Indicator:** A visual padlock icon appears in the browser address bar, confirming that the session is secured via **Transport Layer Security (TLS)** encryption validated by a trusted public Certificate Authority (CA).
- **Standard Port:** Traffic is directed over **TCP Port 443** instead of standard HTTP Port 80.

Step 2: Forensic Wireshark Analysis of `httpsdump.pcap`

Filtering by `tcp.port == 443` or `tls` displays the TLS Handshake (Client Hello, Server Hello, Certificate Exchange, Key Exchange) followed by bidirectional **Application Data** records:

STEP 2.D — PROTOCOL LAYER REPLACEMENT

What has replaced the HTTP section that was in the previous capture file?

DISSECTION FINDING:

The plain-text `Hypertext Transfer Protocol` application layer has been completely replaced by the **Transport Layer Security (TLS) / Secure Sockets Layer (SSL)** protocol layer (e.g., `TLSv1.2 / TLSv1.3 Record Layer: Application Data Protocol: http-over-tls`).

STEP 2.F — CIPHERTEXT & APPLICATION DATA INSPECTION

Is the application data in a plaintext or readable format?

CRYPTOGRAPHIC VERIFICATION:

No. The application data is completely unreadable, represented as high-entropy pseudorandom **Encrypted Application Data (Ciphertext)**:

```
Transport Layer Security
  TLSv1.2 Record Layer: Application Data Protocol: http-over-tls
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 1424
    Encrypted Application Data: 7f8a91b4c3e201d4a8f9021... [1424 bytes]
```

All HTTP headers, URLs, cookies, usernames, and passwords are encrypted by symmetric session ciphers (e.g., AES-GCM, ChaCha20-Poly1305), preventing passive sniffing.

Reflection Questions & Threat Analysis**REFLECTION QUESTION 1 — CORE ADVANTAGES OF HTTPS OVER HTTP**

What are the advantages of using HTTPS instead of HTTP?

SECURITY TRIAD & ARCHITECTURAL BENEFITS:

1. **Data Confidentiality (Encryption):** Protects all transmitted data (PII, passwords, credit cards, medical records) from network eavesdropping, packet sniffing, and unauthorized interceptors.
2. **Data Integrity (Anti-Tampering):** Employs Message Authentication Codes (MAC / AEAD) ensuring packets cannot be altered, modified, or injected with malware/ads in transit without instant connection termination.
3. **Mutual Authentication & Trust:** Digital X.509 certificates cryptographically verify that the user is connecting to the authentic domain owner and not a spoofed phishing server or DNS clone.
4. **Regulatory & Privacy Compliance:** Mandated by security standards worldwide (PCI-DSS, GDPR, HIPAA, ISO 27001).

REFLECTION QUESTION 2 — THE HTTPS TRUST FALLACY IN MODERN THREAT LANDSCAPES

Are all websites that use HTTPS considered trustworthy?

CRITICAL SOC THREAT INTELLIGENCE INSIGHT:

NO. Absolutely not.

Detailed Rationale: HTTPS only guarantees that the connection between the client browser and the server is *encrypted* and that the domain matches the issued digital certificate. It provides **zero guarantee regarding the legitimacy, safety, or moral intent of the website owner.**

- **Abuse by Threat Actors:** Cybercriminals easily obtain free, valid TLS certificates (via Let's Encrypt, Cloudflare, ZeroSSL) for malicious phishing websites, fake banking portals, and malware distribution points.
- **C2 Channel Obfuscation:** Modern malware and Command and Control (C2) frameworks (Cobalt Strike, Sliver, Meterpreter) routinely use HTTPS over Port 443 specifically to blend in with legitimate enterprise web traffic and evade legacy firewall deep packet inspection.
- **User Deception:** Many users mistakenly believe the "secure padlock" means the site is safe to enter credentials, making HTTPS-enabled phishing portals exceptionally dangerous.

SOC Analyst Protocol Comparison Matrix

SECURITY PROPERTY	HTTP (HYPERTEXT TRANSFER PROTOCOL)	HTTPS (HTTP OVER TLS/SSL)
Default Port	TCP Port 80	TCP Port 443
Wire Payload	Plaintext ASCII (Completely readable)	Encrypted Ciphertext (AES-GCM / ChaCha20)
Vulnerability to Sniffing	Critical — Instant credential theft	Protected — Requires TLS decryption key / MitM proxy
Identity Verification	None (Vulnerable to spoofing)	X.509 Certificate Authority Validation
SOC Inspection Strategy	Direct payload analysis with Snort/Suricata	TLS Decryption / SSL Forward Proxy / JA3 Fingerprinting